**Student Name: Nolusindiso Sonjani**

**Student Number: C112617560**

**Course: GRC103**

**Lab: 3**

**Date: 06 November 2026**

## Step 5: Baseline Risk Register

| Risk ID | Asset | Threat Event | Weakness | Impact | Likelihood | Score | Rating | Owner |
|---|---|---|---|---|---|---|---|---|
| R1 | Legacy Endpoint | Unauthorized access to legacy service | Unnecessary service running on port 8080 | 4 | 4 | 16 | High | System Administrator |
| R2 | Archive Files | Sensitive file disclosure | Archive directory publicly accessible | 4 | 4 | 16 | High | Web Administrator |
| R3 | Web Server | Unauthorized network access | No firewall restrictions | 5 | 4 | 20 | Critical | Network Administrator |
| R4 | Portal Content | Data loss or corruption | No tested backup and recovery process | 4 | | | | |

## Step 6: Avoidance Decision Record

### Proposed Change

Retire the unused legacy endpoint running on TCP port 8080 while maintaining the approved NGINX web service on port 80.

### Business Impact

No impact on the approved portal because the service is not required for business operations.

### Approval Role

Simulated approval by IT Manager.

### Test Plan

1. Scan ports before change.
2. Disable service.
3. Scan ports after change.
4. Confirm port 80 remains available.

## Rollback Plan

Shell
sudo systemctl enable --now grc-legacy

## Results

- Port 8080 successfully removed.
- Port 80 remained operational.
- Exposure associated with the legacy endpoint eliminated.

### Explanation

This action avoids the risk by completely removing the unused service. However, risks remain for the active web service on port 80, therefore total organizational risk is not eliminated.

### Step 7: Archive Hardening Explanation

#### Verification Results

| URL | Expected Result |
|---|---|
| /public/ | HTTP 200 |
| /archive/ | HTTP 403 |
| /archive/dummy-records.txt | HTTP 403 |
| / | HTTP 403 |

### Why Disabling Listings Is Not Enough

Disabling directory listings only prevents users from seeing the contents of a folder. If a file name is known, an attacker can still access the file directly. Therefore:

- Autoindex Disabled = Hides directory contents
- Access Denial Rule = Prevents file access completely

The explicit NGINX deny rule provides stronger protection.

## Step 8: Firewall Validation

## Approved Client Test

Source IP: Kali VM

Result:

- HTTP 200 received
- Website accessible

## Blocked Client Test

Source IP: Secondary Kali IP

Result:

- Connection timed out
- No web page received

## Conclusion

The UFW firewall successfully restricted access to approved systems while blocking unauthorized clients. Firewall logs confirmed blocked traffic.

## Step 9: Log Correlation Answers

## Which Requests Appear in NGINX Logs?

Requests that reach the web server successfully:

- /public/
- /archive/

These requests reach NGINX and are therefore recorded in:

Shell

## Why Firewall Blocked Traffic Does Not Appear in NGINX

UFW blocks traffic before it reaches NGINX.

Therefore:

- Blocked traffic appears in UFW logs.
- Blocked traffic does NOT appear in NGINX access logs.

This demonstrates defense in depth.

## Evidence Table

| Test ID | Source IP | Service | Expected | Actual | Log Source |
|---|---|---|---|---|---|
| T1 | Kali | /public/ | HTTP 200 | HTTP 200 | NGINX Access Log |
| T2 | Kali | /archive/ | HTTP 403 | HTTP 403 | NGINX Access Log |
| T3 | Secondary IP | /public/ | Timeout | Timeout | UFW Log |

### Step 10: Recovery Exercise

### Observed Results

1. Backup created successfully.
2. Portal file deleted.
3. Web page unavailable.
4. Backup restored.
5. SHA256 hash matched.
6. Website returned HTTP 200.

### Sample Recovery Time Calculation

| Event | Time |
|---|---|
| Delete File | 10:00 |
| Restore Complete | 10:04 |

Recovery Time:

Plain Text
10:04 - 10:00 = 4 minutes

## Backup Limitation

The backup is stored on the same host. It protects against accidental deletion but does not protect against:

- Complete server failure
- Ransomware
- Disk corruption
- Physical damage to the server

## Step 11: Transfer Exercise

### Managed Backup Service Comparison

| Item | Managed Backup |
|---|---|
| Setup Cost | $120 |
| Monthly Cost | $20 |
| Provider Duties | Backups, storage, monitoring |
| Customer Duties | Security, testing, access management |
| Restoration Testing | Required quarterly |
| Evidence Retention | Backup logs retained 12 months |
| Limitation | Does not eliminate risk |

## Proposed Service Clause

The provider shall maintain scheduled backups and retain backup evidence logs. The customer remains responsible for access control, data classification, and recovery validation testing.

## Step 11: Acceptance Exercise

### Residual Risk Acceptance

| Item | Value |
|---|---|
| Risk | Plain HTTP on isolated network |
| Owner | IT Manager (Simulated) |
| Residual Score | 4 |
| Expiry Period | 14 Days |
| Review Date | 14 Days After Approval |
| Acceptance Status | Temporary |

## Rationale

Plain HTTP may be temporarily accepted because:

- Network is isolated.
- Only dummy training data is hosted.
- No external connectivity exists.

Acceptance must be reviewed if:

- Real data is introduced.
- Internet access is enabled.
- Additional users gain access.

## Step 12: Cost Analysis

## Option A: Hardening

Labour:

Plain Text
4 × $25 = $100

Maintenance:

Plain Text
$50

First Year Cost:

Plain Text
$150

## Option B: Managed Backup

Plain Text
$120 + (12 × $20)
= $360

## Option C: TLS Deployment

Labour:

Plain Text
3 × $25 = $75

Maintenance:

Plain Text
$25

First Year Cost:

Plain Text
$100

## Recommended Combination

- Option A (Hardening)
- Option B (Managed Backup)
- Option C (TLS)

Total First-Year Cost:

Plain Text
$150 + $360 + $100
= $610

This combination provides preventive, detective, and corrective control coverage.

## ALE Calculation

Baseline ALE:

Plain Text
ARO × Loss
0.2 × $5,000
= $1,000

Residual ALE:

Plain Text
0.2 × $1,000
= $200

Annual Benefit:

Plain Text
$1,000 - $200
= $800

First-Year Net Benefit:

Plain Text
$800 - $360
= $440

### Residual Risk Register

| Risk | Residual Likelihood | Impact | Score | Rating |
|---|---|---|---|---|
| R1 Legacy Service | 1 | 4 | 4 | Low |
| R2 Archive Exposure | 1 | 4 | 4 | Low |
| R3 Unauthorized Access | 2 | 4 | 8 | Medium |
| R4 Data Loss | 2 | 4 | 8 | Medium |